CPE 334 LAB 3 ENGINEERING EVIDENCE REPORT

TokTickIT: Users, Roles, IT Staff Ticketing, and Admin Screens

Student: Wichitchai Suwanno (67070503439) | GitHub: `SinghLemonH`
Partner / Reviewer: Wathit Tritsananawakit (67070403495) | GitHub: `WATHITx`
Repository: SinghLemonH/toktickit
Main Branch Target: main (via lab3-staging)

1. Answer Part 1: Git Use with Engineering Workflow

1.1 Repository and Workflow URLs:

- **GitHub Repository:** https://github.com/SinghLemonH/toktickit
- **GitHub Project Kanban Board:** https://github.com/users/SinghLemonH/projects/2/views/1
- **Sprint 3 Issues:** #29 (Contract), #30 (DB Evolution), #31 (Auth Engine), #32 (Requester & Comments), #33 (Staff Queue & Ops), #34 (Admin Users), #35 (E2E Release)
- **Sprint 3 Pull Requests:** PR #37 (Issue #29), PR #38 (Issue #30), PR #39 (Issue #31), PR #40 (Issue #32), PR #41 (Issue #33), PR #42 (Issue #34), PR #43 (Issue #35), Release PR #45 (staging to main)

1.2 GitHub Project Kanban Board (All Issues in Done)

The screenshot below demonstrates the live GitHub Project board where all 7 Sprint 3 issues have transitioned to the **Done** column following peer review and QA verification:

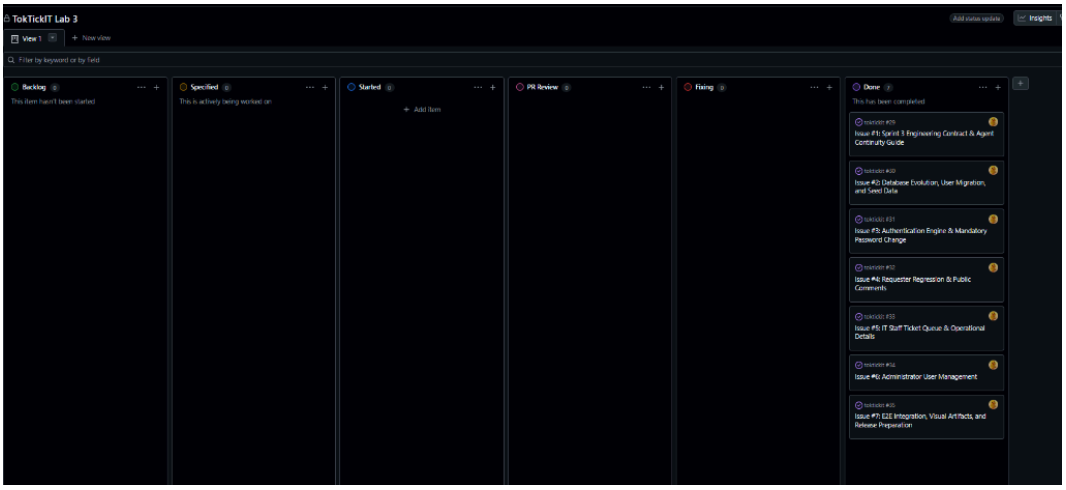


Figure 1.1: GitHub Project Kanban Board with all Sprint 3 issues in Done state.

1.3 Git Commit History Graph on Main Branch

The Git graph below confirms that each feature was built on an isolated branch, merged into `lab3-staging` via pull request with peer review, and finally released to `main` in PR #45:



Figure 1.2: Git commit history graph demonstrating feature branch isolation, staging integration, and main release.

1.4 Peer Review Record (Rendered docs/lab-03/reviewer.md)

PR	Issue	Reviewer	Merge Commit	Reviewer Feedback Summary
PR #37	#29 (Contract & Guide)	@WATHITx	`96894da`	Approved: Comprehensive specification contracts and invariants established upfront.
PR #38	#30 (DB Evolution & Seed)	@WATHITx	`4a638b9`	Approved: Expand-and-contract schema evolution preserves Lab 2 backward compatibility.
PR #39	#31 (Auth & Pass Change)	@WATHITx	`ba7f526`	Approved: Cookie session security and mandatory password change quarantine verified.
PR #40	#32 (Requester Comments)	@WATHITx	`314cb8f`	Approved: Public comments and Problem Appears Resolved flag implemented cleanly.
PR #41	#33 (Staff Operations)	@WATHITx	`0f5145d`	Approved: Ticket queue, BR-15 status transitions, and confidential internal notes verified.
PR #42	#34 (User Management)	@WATHITx	`b91c91e`	Approved: Administrator safety guards (BR-16 self-deactivation, BR-17 last admin) solid.
PR #43	#35 (E2E & Release QA)	@WATHITx	`be577ae`	Approved: 165/165 tests passing, responsive testing on all viewports verified.
PR #45	Release QA (staging to main)	Self / Partner	`2620972`	Final QA release merged into main with clean test baseline.

1.5 Repository Directory Structure & .gitignore Verification

Directory tree strictly adheres to bounded architectural layers across `docs/lab-03/`, `server/`, `client/`, and `e2e/lab-03/`. Due to deep dependency hierarchies (`node_modules`) and build targets, the active repository structure is curated below (depth 2-3) alongside verified `.gitignore` rules:

Architectural Directory Tree (Depth 2-3):

```
toktickit/
├── client/                 (React + Vite + Zen Green)
│   ├── src/
│   │   ├── components/     (AppShell, RouteGuard)
│   │   ├── context/        (Auth, Requester)
│   │   ├── pages/          (Login, Queue, Detail, Admin)
│   │   └── AppRouter.tsx   (Guarded RBAC routes)
│   └── tests/lab-03/       (Component unit tests)
├── server/                 (Express + TypeScript + Prisma)
│   ├── prisma/             (Schema evolution & seed)
│   ├── src/
│   │   ├── auth/           (Cookie session engine)
│   │   ├── middleware/     (Auth & RBAC quarantine)
│   │   └── routes/         (Auth, tickets, notes, admin)
│   ├── tests/lab-03/       (API integration & RBAC)
│   └── uploads/            (Attachment storage)
├── docs/lab-03/            (Specifications, tests, logs)
│   └── screenshots/        (Visual evidence artifacts)
```

Figure 1.3a: Repository architectural tree (dependencies excluded).

.gitignore Rules Configuration:

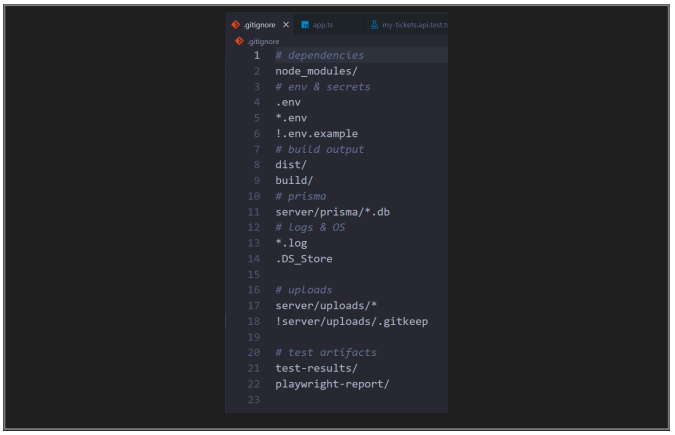


Figure 1.3b: Active .gitignore rules isolating dependencies, env secrets, and DBs.

2. Answer Part 2: Spec DD (Specification-Driven Development)

Specification Contract Files: docs/lab-03/specification.md, docs/lab-03/api-spec.md, and docs/lab-03/ui-spec.md. All specifications were merged and approved in PR #37 prior to implementation PRs.

2.1 Numbered Functional Requirements (FR-01 to FR-20 Summary)

FR ID	Module	Requirement Summary
FR-01 to FR-06	Authentication & Session	Email/password auth with bcrypt, HTTP-only signed cookie (`toktickit_session`), mandatory first-login password quarantine, /api/auth/me session check, and session termination via /api/auth/logout.
FR-07 to FR-10	Requester & Legacy Continuity	Identity derived strictly from session (DevRequester retired), ticket creation and ticket viewing bound to authenticated requester, public comments, and Problem Appears Resolved indicator.
FR-11 to FR-15	IT Staff Operations	Staff Ticket Queue with debounced text search, multi-filter dropdowns, sorting, and pagination. Claim ticket ownership, reassign staff, update IT Priority, and execute BR-15 permitted status transitions.
FR-16 to FR-20	Admin User Management	User directory table with search and role filter, account creation with compliant initial password generator, edit account details, reset initial password, and enforce invariant safety guards (BR-16, BR-17).

2.2 Role-Based Authorization Matrix (RBAC)

Screen / Capability	Requester	IT Staff	Administrator	Enforcement Mechanism
Login / Logout / Change Password	Allowed	Allowed	Allowed	`authenticateSession` middleware
View Owned Tickets (`/tickets`)	Allowed (Own)	Allowed (Own)	Allowed (Own)	Filtered to `req.user.id`
Staff Ticket Queue (`/staff/queue`)	Forbidden (403)	Allowed	Allowed	`requireRole(["IT_STAFF", "ADMINISTRATOR"])`
Claim / Reassign Ticket	Forbidden (403)	Allowed	Allowed	`requireRole(["IT_STAFF", "ADMINISTRATOR"])`
Set IT Priority & Change Status	Forbidden (403)	Allowed	Allowed	BR-15 Permitted State Machine Validation
Public Comments Stream	Allowed (Own)	Allowed (All)	Allowed (All)	Shared ticket communication
Confidential Internal Notes	Forbidden (403)	Allowed	Allowed	Dual-channel confidentiality guard (BR-06)
User Management (`/admin/users`)	Forbidden (403)	Forbidden (403)	Allowed	`requireRole(["ADMINISTRATOR"])`

2.3 Database Migration Strategy & Product Definition of Done (DoD)

Migration Decisions: Adopted the Expand-and-Contract migration pattern. DevRequester records were preserved during transition and migrated directly into the unified `User` model with bcrypt hashes. `Ticket.requesterId` foreign keys were rebound to `User.id` without data loss. Legacy `PENDING` ticket status was preserved in schema while operational transitions strictly follow BR-14.

Product Definition of Done: (1) All 20 ACs pass in automated tests; (2) Zero DevRequester remnants in production client; (3) Clean Prisma migrations and idempotent seed; (4) 100% automated test suites passing; (5) Zero layout overflow on mobile (375px), tablet (768px), and desktop (1280px); (6) Documentation 100% written in English with zero em dashes.

3. Answer Part 3: Test DD and Traceability

Traceability Reference: Documented in `docs/lab-03/tests.md`. 100% of Acceptance Criteria map directly to automated tests across API, Component, and E2E layers.

3.1 Planned-Test Traceability Matrix (Excerpt)

Test ID	Layer	AC	Target Behavior	Automated Test File	Status
API-01	API	AC-01	Valid credentials issue HTTP-only session cookie	`server/tests/lab-03/auth.api.test.ts`	**Passed**
API-04	API	AC-04	Quarantine access when mustChangePassword is true	`server/tests/lab-03/auth.api.test.ts`	**Passed**
API-10	API	AC-10	Requester forbidden from Internal Notes (403)	`server/tests/lab-03/comments-notes.api.test.ts`	**Passed**
API-11	API	AC-11	Staff Queue search, filter, and pagination	`server/tests/lab-03/staff-queue.api.test.ts`	**Passed**
API-14	API	AC-14	BR-15 Permitted status transitions validation	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	**Passed**
API-18	API	AC-18	Admin self-deactivation rejected with 400	`server/tests/lab-03/users-admin.api.test.ts`	**Passed**
API-19	API	AC-19	Last active admin removal rejected with 409	`server/tests/lab-03/users-admin.api.test.ts`	**Passed**
UI-01	Component	AC-01	Login form validation and safe error feedback	`client/tests/lab-03/Login.test.tsx`	**Passed**
UI-02	Component	AC-04	Password complexity real-time checklist	`client/tests/lab-03/ChangePassword.test.tsx`	**Passed**
UI-03	Component	AC-11	Staff Queue table, debouncing, and badges	`client/tests/lab-03/StaffTicketQueue.test.tsx`	**Passed**
UI-04	Component	AC-12	Staff Ticket Detail operational controls & tabs	`client/tests/lab-03/StaffTicketDetail.test.tsx`	**Passed**
UI-05	Component	AC-18	Admin User Management safety guards	`client/tests/lab-03/UserManagement.test.tsx`	**Passed**
E2E-01	E2E	AC-01	End-to-end login, app shell navigation, logout	`e2e/lab-03/authentication.spec.ts`	**Passed**
E2E-02	E2E	AC-04	Mandatory password change first-login flow	`e2e/lab-03/authentication.spec.ts`	**Passed**
E2E-03	E2E	AC-12	Complete Staff ticket handling lifecycle	`e2e/lab-03/staff-ticket-flow.spec.ts`	**Passed**
E2E-04	E2E	AC-16	Admin user management & safety guards	`e2e/lab-03/user-administration.spec.ts`	**Passed**

3.2 Passing Automated Test Execution Output from Main (165/165 Passed)

The following terminal console screenshots demonstrate 100% passing automated tests (165/165 total) on the `main` branch, covering the Express backend API, React client components, and Playwright end-to-end integration flows:

Backend API & Unit Test Suites (server/ - 14 test files, 111 passed):

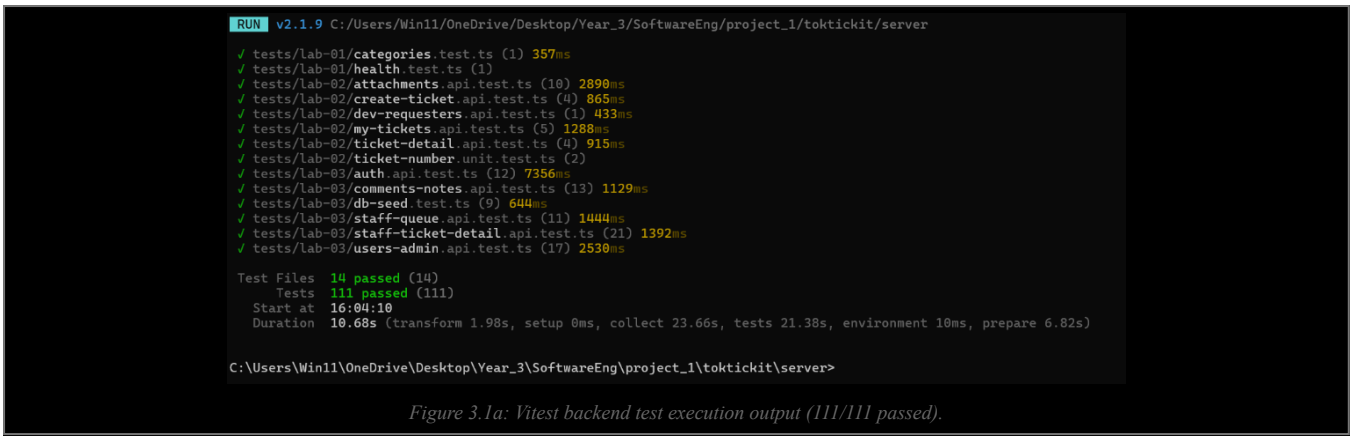


Figure 3.1a: Vitest backend test execution output (111/111 passed).

Frontend Component Test Suites (client/ - 14 test files, 47 passed):



Figure 3.1b: Vitest React Testing Library component test output (47/47 passed).

Playwright End-to-End Integration Suites (root - 7 test flows, 7 passed):



Figure 3.1c: Playwright end-to-end integration test output (7/7 passed).

4. Answer Part 4: AI Use with Reflection

AI Assistant Tooling: Google Antigravity Agent with Google Gemini. Full log in `docs/lab-03/ai-use.md`.

4.1 Selected Key Prompts Table

Prompt Topic	Actual Prompt / Context Framing
Strategic Architecture & RBAC	"Act as a Principal Software Architect. Analyze trade-offs between HTTP-only secure cookie sessions versus Bearer JWT. Define strict server-side RBAC invariants for Express + TypeScript + Prisma + React."
Formal Contract Synthesis (Spec DD)	"Draft formal engineering specification for Sprint 3. Explicitly define: (1) Numbered Functional Requirements (FR-01+); (2) Invariant Business Rules (BR-01+) including admin safety guards; (3) Observable Acceptance Criteria (AC-01+)."
Defensive REST API Contract	"Design complete REST API contract under /api. Ensure uniform JSON error responses. Ensure Requester attempts to access Internal Notes return 403 Forbidden."
DB Evolution & Seed (Issue #30)	"Execute database evolution using Expand-Contract pattern: retain DevRequester during transition, migrate existing data to User with bcrypt hashes, update Ticket relations, and build idempotent seed script."
Auth Engine & Quarantine (Issue #31)	"Construct authentication engine using signed cookies (toktickit_session). Build middleware detecting mustChangePassword: true and quarantining users to Change Password screen with live complexity checklist."
Comments Stream & Isolation (Issue #32)	"Retire legacy /select-requester. Implement Public Comments stream and Problem Appears Resolved flag workflow without prematurely mutating ticket status to RESOLVED."
Staff Queue & Operations (Issue #33)	"Build Staff Ticket Queue with multi-filter search, sorting, and pagination. Implement ticket claim/reassign, independent IT Priority, BR-15 permitted status transitions, and amber confidential internal notes."
Admin User Management (Issue #34)	"Build User Management (/admin/users). Enforce safety invariants: mandatory initial password with safe generator, prevention of self-deactivation (BR-16), and prevention of deactivating the last active admin (BR-17)."
E2E Integration & QA (Issue #35)	"Implement Playwright E2E suites covering E2E-01 to E2E-04. Capture responsive screenshot evidence across Desktop (1280x800), Tablet (768x1024), and Mobile (375x667)."

4.2 My Reflection on AI Use

Using an AI pair programmer with Spec-Driven Development (Spec DD) and Test-Driven Development (TDD) elevated velocity while enforcing architectural rigor. Dividing the AI into two roles: The Specification Agent for upfront RFC-style contract drafting and threat modeling, and The Coding Agent for test-backed implementation: prevented hallucination and scope creep. Human architectural oversight was vital in enforcing security invariants: ensuring server-side RBAC validation cannot be bypassed by client-side UI inspection, preserving administrative accounts against self-lockout, and executing zero-downtime database migrations without breaking legacy sprint test suites.

5. Answer Part 5: Working Login and Password Change UI

5.1 Authentication Feedback (Valid, Invalid, and Inactive Account Block)

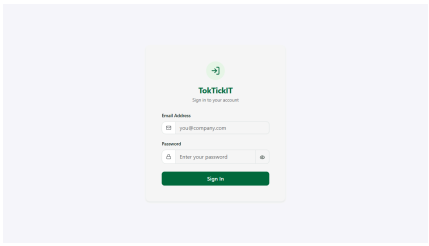


Figure 5.1a: Zen Green Login Screen (/login).

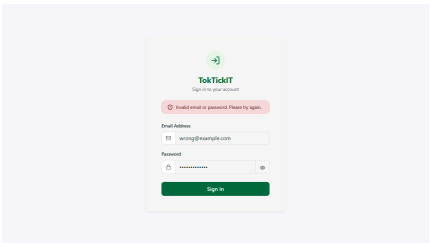


Figure 5.1b: Invalid credentials generic error.

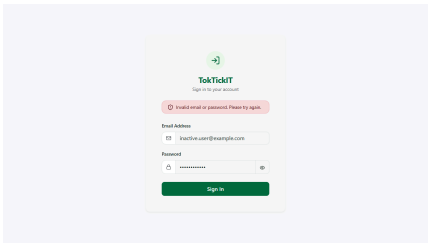


Figure 5.1c: Inactive account blocked with generic error (BR-02).

5.2 Mandatory First-Login Password Quarantine & Complexity Checklist

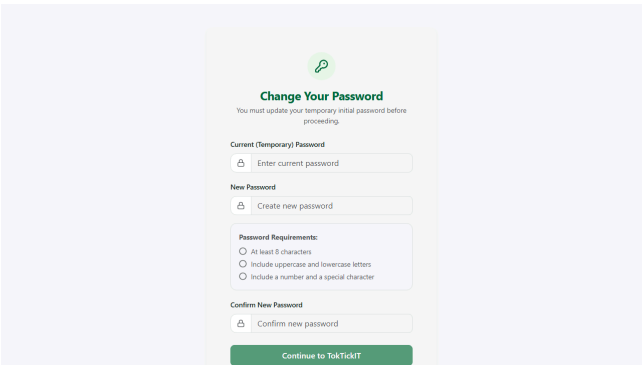


Figure 5.2a: Quarantine screen on first sign-in (Submit disabled).

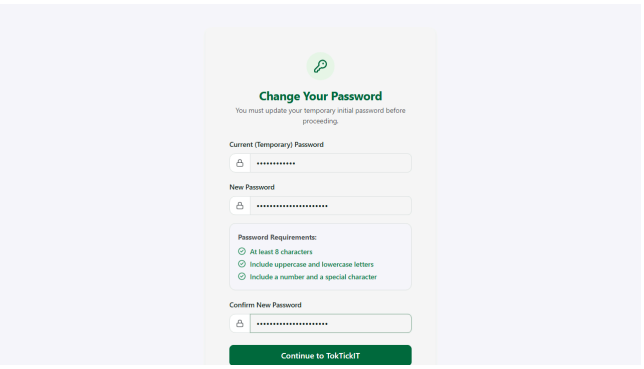


Figure 5.2b: Live complexity checklist turns green upon valid input.

5.3 App Shell with Role Badges & Direct Access Blocked after Logout

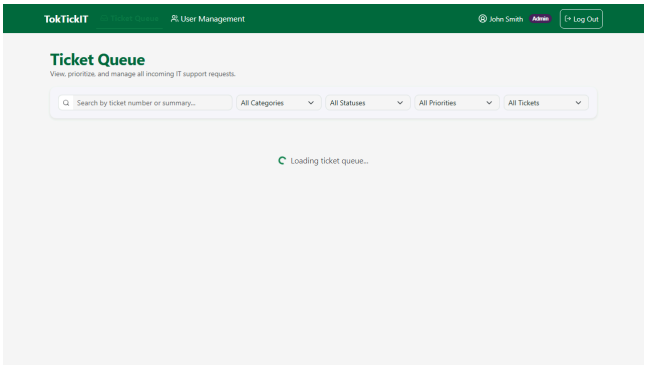


Figure 5.3a: Authenticated app shell showing role badges (Admin).

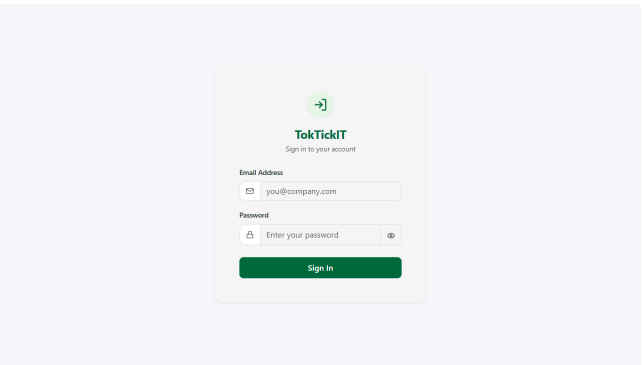


Figure 5.3b: Cookie destroyed; redirected to login; direct access blocked.

6. Answer Part 6: Working IT Staff Ticket Queue UI

6.1 Realistic Queue Data, Search, Multi-Filter, Sorting & Pagination

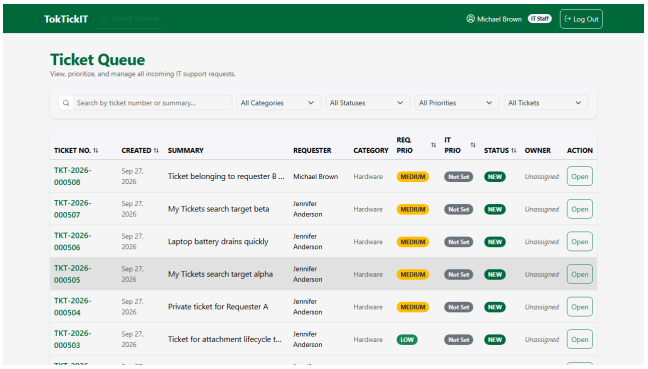


Figure 6.1a: IT Staff Queue showing columns, priority badges, status pills, and owner assignments.

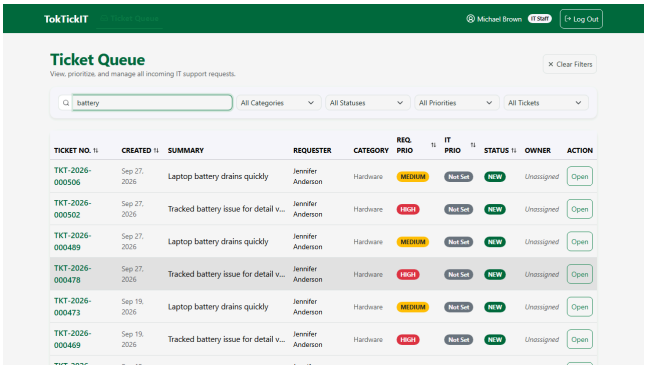


Figure 6.1b: Real-time debounced search by summary keyword and multi-parameter dropdown filtering.

6.2 Column Sorting, Pagination State & Empty Filter Feedback

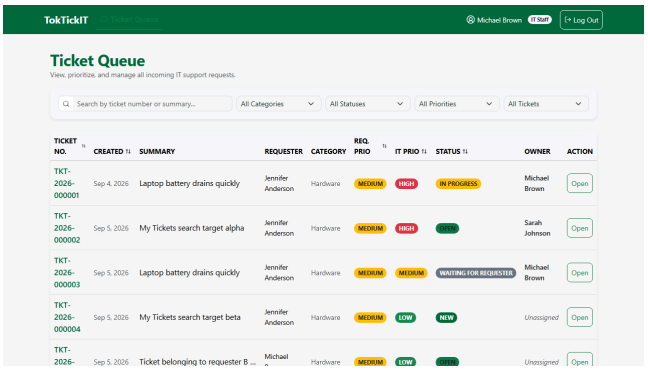


Figure 6.2a: Active column sorting with indicator and operational pagination controls.

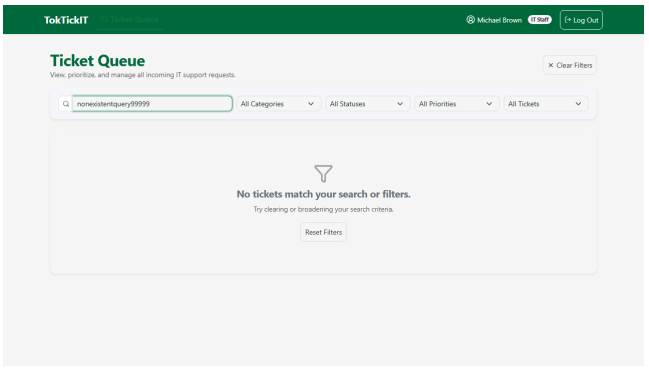


Figure 6.2b: Clean empty/no-results feedback when no tickets match active filter criteria.

7. Answer Part 7: Working IT Staff Ticket Detail UI

7.1 Operational Controls: Claim/Reassign, IT Priority & Permitted Status Transitions

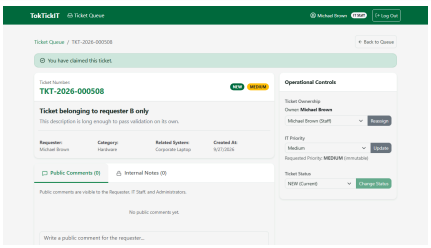


Figure 7.1a: Ticket claimed by staff.

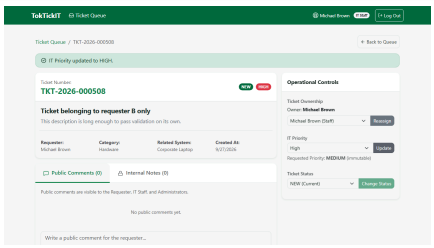


Figure 7.1b: IT Priority updated independently.

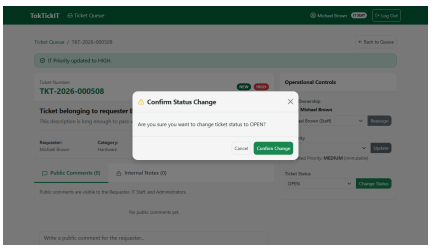


Figure 7.1c: BR-15 Status change modal.

7.2 Dual-Channel Communication: Public Comments vs Confidential Internal Notes

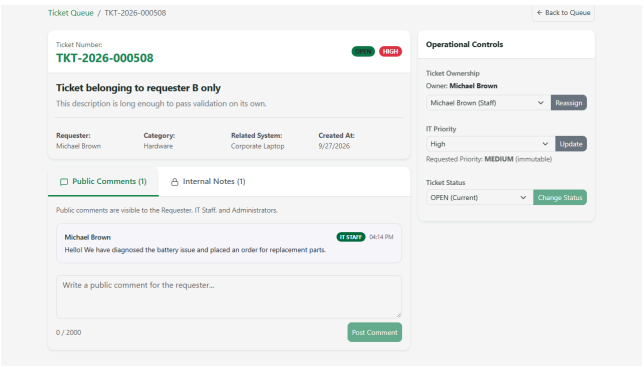


Figure 7.2a: Public comments stream visible to Requesters and Staff.

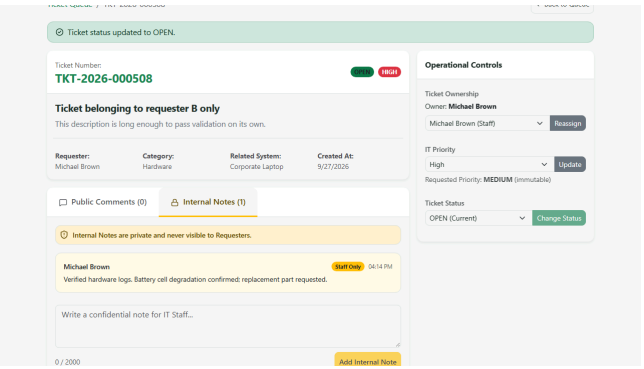


Figure 7.2b: Amber-styled confidential Internal Notes (strictly staff-only).

7.3 Attachment Continuity & Requester Resolution Indication

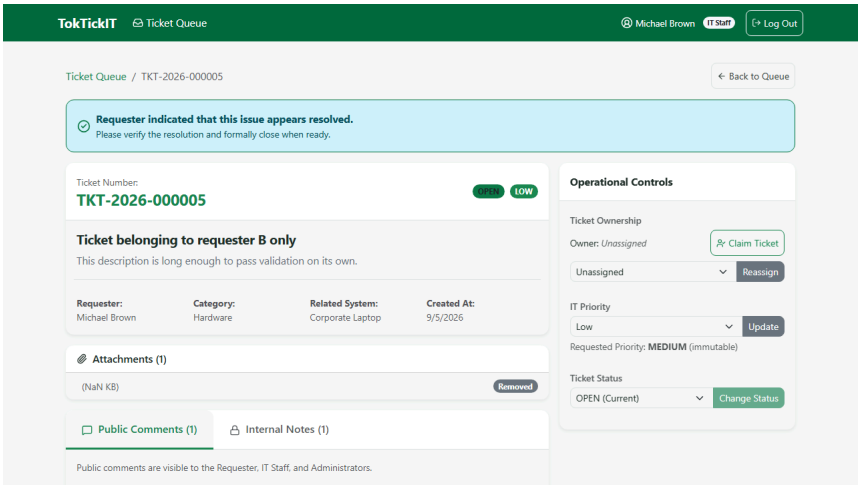


Figure 7.3: Blue banner indicating Requester problem resolution alongside preserved Lab 2 attachments section.

7.4 Direct API Authorization Evidence (Server-Side RBAC Verification)

The following real API execution traces prove that RBAC is enforced strictly at the Express middleware layer, rejecting unauthorized direct API calls even when requested with valid user session tokens:

```
# Test 1: Requester attempting to write confidential Internal Note (AC-10 / BR-06)
$ curl -i -X POST http://localhost:3000/api/staff/tickets/1/notes   -H "Cookie: toktickit_session=<VALID_REQUES
TER_TOKEN>"   -H "Content-Type: application/json"   -d '{"content": "Unauthorized attempt to create internal no
te"}'

HTTP/1.1 403 Forbidden
Content-Type: application/json; charset=utf-8
{"error": "Access forbidden: Insufficient permissions"}

# Test 2: IT Staff attempting to access Administrator User Management (AC-20 / BR-05)
$ curl -i -X GET http://localhost:3000/api/admin/users   -H "Cookie: toktickit_session=<VALID_IT_STAFF_TOKEN>"

HTTP/1.1 403 Forbidden
Content-Type: application/json; charset=utf-8
{"error": "Access forbidden: Insufficient permissions"}

# Test 3: Unauthenticated user attempting to query Staff Queue (BR-01)
$ curl -i -X GET http://localhost:3000/api/staff/tickets

HTTP/1.1 401 Unauthorized
Content-Type: application/json; charset=utf-8
{"error": "Authentication required"}
```

8. Answer Part 8: Working Administrator User Management UI

8.1 User Directory, Search, Role Badges & Status Pills

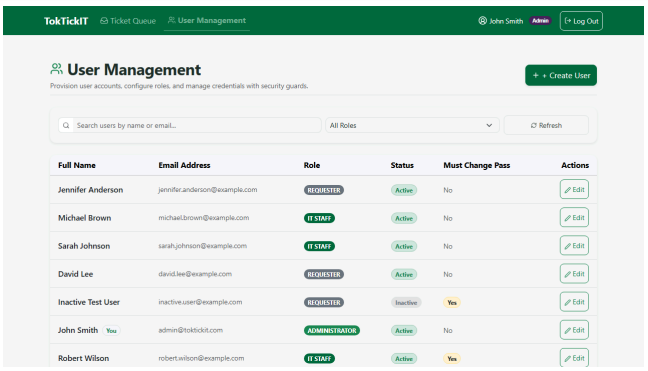


Figure 8.1a: Minimalist Administrator User Management (/admin/users) with role badges and active status pills.

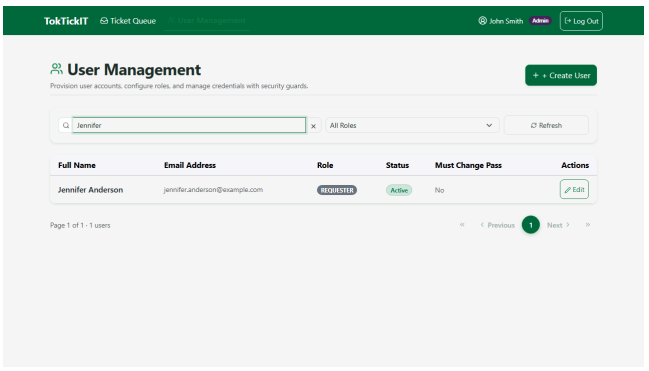


Figure 8.1b: Real-time search by user name or email address.

8.2 Account Provisioning, Initial Password Reset & Duplicate Email Conflict Error

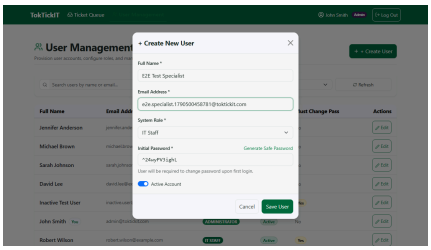


Figure 8.2a: Create User modal with Generate Safe Password button.

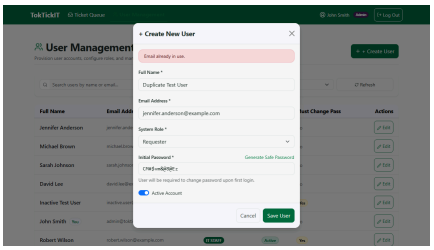


Figure 8.2b: Duplicate email conflict error banner (AC-17).

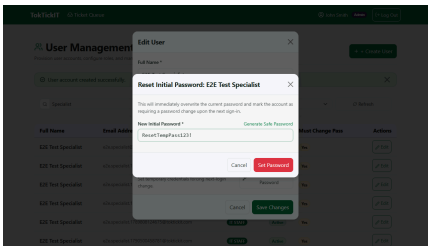


Figure 8.2c: Administrative password reset dialog.

8.3 Invariant Safety Guards & Non-Admin Forbidden Access

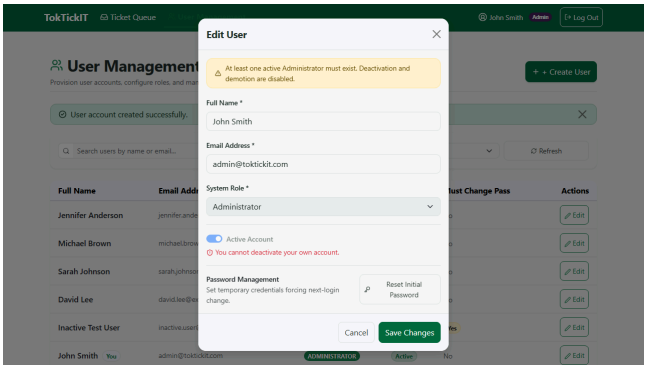


Figure 8.3a: Self-deactivation prevention guard (BR-16) and last admin guard (BR-17).

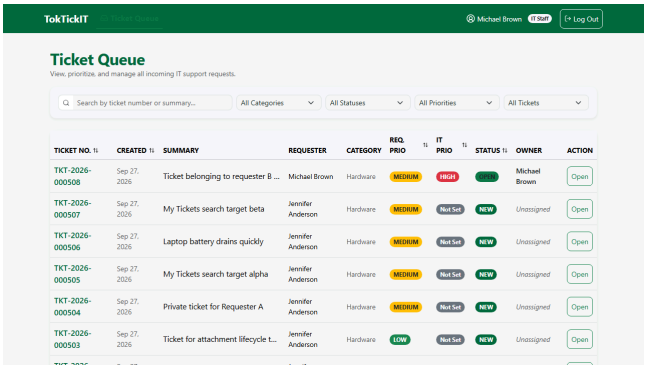


Figure 8.3b: Non-admin IT Staff blocked from accessing /admin/users and redirected away.

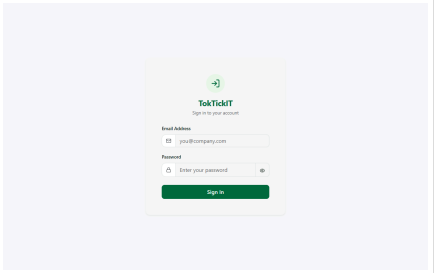
9. Answer Part 9: Zen Green UI and Responsive Evidence

9.1 Rendered UI Specification Summary (docs/lab-03/ui-spec.md)

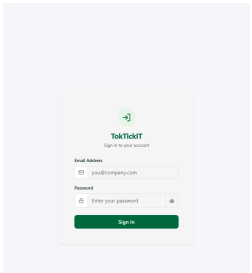
Design Token / Parameter	Specification Standard	Implementation Evidence
Color Hierarchy (Zen Green)	Primary: #006B3C, Hover: #00522E, Surface: #E8F5E9, Amber: #D97706	Verified in CSS variable overrides (`theme.css`). Contrast >= 4.5:1 on all text elements.
Typography System	System Sans-Serif font stack (-apple-system, BlinkMacSystemFont, Segoe UI)	Clear font size hierarchy: h1 (24px), h2 (20px), body (14px), small (12px).
Responsive Breakpoints	Desktop (1280px), Tablet (768px), Mobile (375px)	Full fluid grid with no unwanted horizontal scroll at 375px mobile viewport.
Component States	Busy spinners on all buttons, disabled states during API calls, safe error alerts	Verified across all forms (Login, Password Change, Status Modal, User Management).

9.2 Responsive Layout Evidence across 3 Viewports

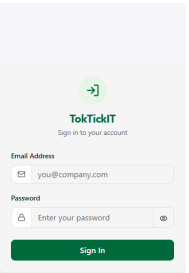
Login Screen:



Desktop (1280px)

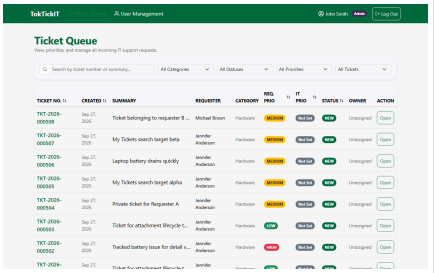


Tablet (768px)

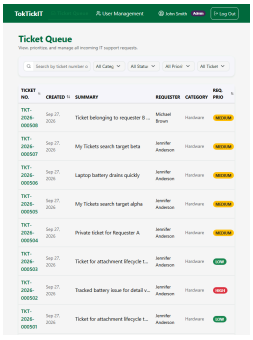


Mobile (375px)

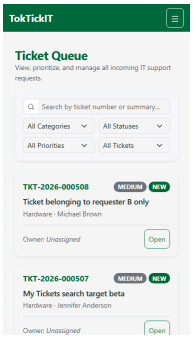
Staff Ticket Queue Screen:



Desktop (1280px)

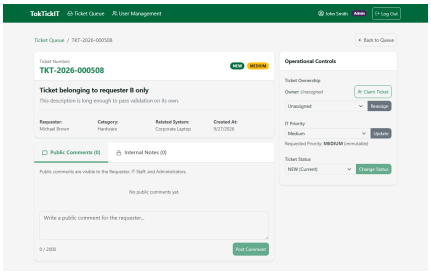


Tablet (768px)

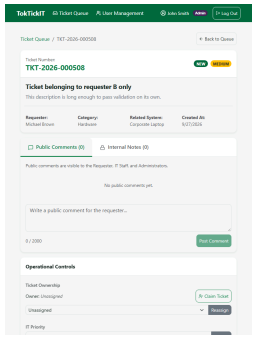


Mobile (375px)

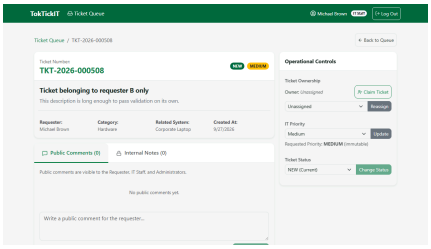
Staff Ticket Detail Screen:



Desktop (1280px)

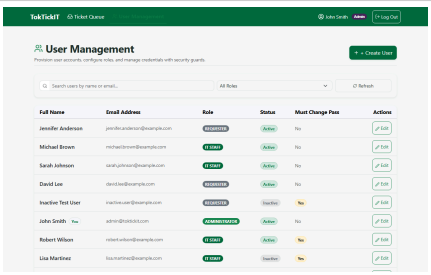


Tablet (768px)

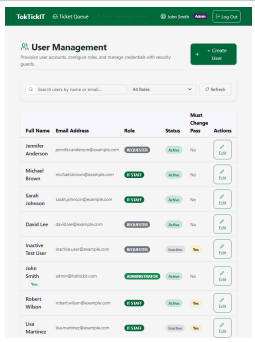


Mobile (375px)

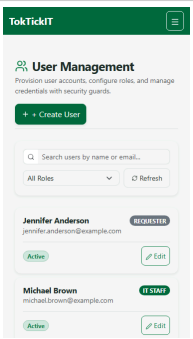
Administrator User Management Screen:



Desktop (1280px)



Tablet (768px)



Mobile (375px)

9.3 Completed Visual Checklist

Design Requirement	Implementation Evidence	Status
Zen Green Color Palette	App header, primary buttons, and badges use #006B3C, #00522E, and #E8F5E9.	**VERIFIED**
Editable vs Read-only Inputs	Requester detail is strictly read-only; staff operational controls clearly grouped.	**VERIFIED**
Button Hierarchy & Busy State	Primary Zen Green buttons show spinners and disable during API in-flight requests.	**VERIFIED**
No Horizontal Overflow	All screens verified at 375px mobile viewport without unwanted horizontal scroll.	**VERIFIED**
Accessibility & Status Badges	All status and priority badges include text labels and directional icons. Contrast >= 4.5:1.	**VERIFIED**
Safety Guard Tooltips & Alerts	Admin self-deactivation and last admin removal blocked with explicit explanation banners.	**VERIFIED**